

THREATS AND VULNERABILITY ASSESSMENT

Threats and Threat Sources

A **threat** is the potential occurrence of an undesirable event that can eventually damage and disrupt the operational and functional activities of an organization. It can be any entity or action performed on physical or intangible assets that can disrupt security. The existence of threats may be **accidental**, **intentional**, or due to the **impact of another action**.

Attackers use **cyber threats** to infiltrate and steal data such as personal information, financial information, and login credentials. They can also use a **compromised system** to perform malicious activities and launch further attacks.

The criticality of a threat is based on how much damage it can cause, how uncontrollable it is, and the level of complexity in identifying the latest discovered threat incident in advance.

Threats to data assets can cause:

- Loss of confidentiality, integrity, or availability (CIA) of data
- Data loss
- Identity theft
- Cyber sabotage
- Information disclosure

Examples of Threats

- An attacker causes a server to shut down
- An attacker infects a system with malware
- An attacker stealing sensitive data of an organization
- An attacker performing URL redirection or URL forwarding
- An attacker remotely alters the data in a database server
- An attacker performing privilege escalation for unauthorized access
- An attacker tricking an employee into revealing sensitive information
- An attacker spoofing the identity of an authorized person to gain access
- An attacker modifying or tampering with the data transferred over a network
- An attacker executes denial-of-service (DoS) attacks to make resources unavailable
- An attacker eavesdrops on a communication channel without authorized access

Threat Sources

The following are the various sources from which threats originate. They can be broadly classified as natural threats, unintentional threats, and intentional threats.

- **Natural Threats:** Natural factors such as fires, floods, power failures, lightning, meteors, and earthquakes are potential threats to the assets of an organization. For example, these may cause severe physical damage to computer systems.
- **Unintentional Threats:** Threats that exist due to the potential for unintentional errors occurring within the organization. Examples include insider-originating security breaches, negligence, operator errors, unskilled administrators, lazy or untrained employees, and accidents.

- **Intentional Threats**

There are two (2) sources of intentional threats:

- **Internal Threats**

Most computer and Internet-related crimes are insider or internal attacks. These threats are performed by insiders within the organization, such as disgruntled or negligent employees, and harm the organization intentionally or unintentionally. Most of these attacks are performed by privileged users of the network.

The causes of insider attacks could be revenge, disrespect, frustration, or a lack of security awareness. Insider attacks are more dangerous than external attacks because insiders are familiar with the network architecture, security policies, and regulations of the organization. Additionally, security measures and solutions typically focus more on external attacks, potentially leading an organization to be under-equipped to identify and counter internal attacks.

- **External Threats**

External attacks are performed by exploiting vulnerabilities that already exist in a network, without the assistance of insider employees. Therefore, the potential to perform an external attack depends on the severity of the identified network weaknesses. Attackers may perform such attacks for financial gain, to damage the reputation of the target organization, or simply for the sake of curiosity.

External attackers can be individuals with expertise in attack techniques or a group of people who work together with a shared motive. For example, attacks can be performed with the objective of supporting a cause, by competitor companies for corporate espionage, and by countries for surveillance. Attackers performing external attacks have a predefined plan and use specialized tools and techniques to successfully penetrate networks. External attacks can include application- and virus-based attacks, password-based attacks, instant messaging-based attacks, network traffic-based attacks, and operating system (OS)-based attacks.

External threats are further classified into two (2) types.

- **Structured External Threats:** Implemented by technically skilled attackers, using various tools to gain access to a network to disrupt services. The motivation behind such attacks includes criminal bribes, racism, politics, terrorism, etc. Examples include distributed ICMP floods, spoofing, and simultaneously executing attacks from multiple sources. Tracking and identifying an attacker executing such an attack can be challenging.
 - **Unstructured External Threats:** Implemented by unskilled attackers, typically script kiddies who may be aspiring hackers, to access networks. Most of these attacks are performed primarily out of curiosity, rather than with criminal intentions.

For example, untrained attackers use freely available online tools for attempting a network attack or for crashing a website or other public domains on the Internet. Unstructured external threats can easily be prevented by adopting security solutions such as port-scanning and address-sweeping tools.

Components of Malware and Countermeasures

A **malware** is a piece of malicious software that is designed to perform activities as intended by the attacker, without user consent. This may be in the form of executable code, active content, scripts, or other kinds of software.

Listed below are various types of malware:

- **Trojan:** A program in which malicious or harmful code is contained inside a harmless program or data, which can later gain control and cause damage, such as ruining the file allocation table on a hard disk.

Attackers use computer Trojans to trick the victim into performing a predefined action. Trojans are activated upon users' specific predefined actions, such as unintentionally installing malicious software, clicking on a malicious link, etc., and upon activation, they can grant attackers unrestricted access to all the data stored on the compromised information system and potentially cause severe damage.

For example, users could download a file that appears to be a movie, but, when executed, unleashes a dangerous program that erases the hard drive or sends credit card numbers and passwords to the attacker.

Types of Trojans include Remote Access Trojans, Backdoor Trojans, Botnet Trojans, Rootkit Trojans, and Defacement Trojans, among many others.

To prevent Trojan infections, users should avoid untrusted files, block unused ports, apply system patches, and limit software installations through permission controls. Regular scanning, integrity checks, and the use of antivirus, firewalls, and intrusion detection systems enhance overall protection.

- **Virus:** A self-replicating program that produces its code by attaching copies of itself to other executable code and operates without the knowledge or consent of the user. Like a biological virus, a computer virus is contagious and can contaminate other files; however, viruses can infect external machines only with the assistance of computer users.

A virus reproduces its code while enclosing other executables and spreads throughout the computer. Viruses can spread the infection by damaging files in a file system. Some viruses reside in the memory and may infect programs through the boot sector. A virus can also be in an encrypted form.

Types of viruses include System or Boot Sector Virus, File Virus, Multipartite Virus, Macro Virus, Cluster Virus, and Stealth Virus, among many others.

- **Computer Worms:** Standalone malicious programs that replicate, execute, and spread across network connections independently without human intervention. Intruders design most worms to replicate and spread across a network, thus consuming available computing resources and, in turn, causing network servers, web servers, and individual computer systems to become overloaded and stop responding. However, some worms also carry a payload (used to delete or modify files to compromise system security) to damage the host system.

Worms are a subtype of viruses. A worm does not require a host to replicate; however, in some cases, the worm's host machine is also infected.

To counter viruses and worms, users should install and regularly update antivirus software, avoid suspicious files and email attachments, perform data backups, and scan drives frequently. Additional measures include using pop-up blockers and firewalls, checking media for infections, running weekly cleanups, and being cautious with file types and instant messages.

- **Ransomware:** A type of malware that restricts access to the infected computer system or critical files and documents stored on it, and then demands an online ransom payment to the malware creator(s) to remove user restrictions. It is a type of crypto-malware that might encrypt files stored on the system's hard disk or merely lock the system and display messages meant to trick the user into paying the ransom.

After execution, the payload in the ransomware runs and encrypts the victim's data (files and documents), which can be decrypted only by the malware author. In some cases, user interaction is restricted using a simple payload.

Examples of ransomware include Dharma, SamSam, Ryuk, GandCrab, and WannaCry.

- **Rootkit:** Software programs designed to gain access to a computer without being detected. They are malware that help attackers gain unauthorized access to a remote system and perform malicious activities. The goal of a rootkit is to gain root privileges on a system.

By logging in as the root user of a system, an attacker can perform various tasks such as installing software or deleting files. It works by exploiting the vulnerabilities in the OS and its applications. It builds a backdoor login process in the OS via which the attacker can evade the standard login process.

Rootkits are used to hide viruses, worms, bots, etc., and are difficult to remove. Malware hidden by rootkits is used to monitor, filter, or steal sensitive information and resources, change the configuration settings of the target computer, and perform other potentially unsafe actions.

To defend against rootkits, users should back up data, reinstall software from trusted sources, patch systems regularly, and use up-to-date antivirus software with rootkit protection. Additional safeguards include enforcing the least privilege principle, disabling unused services, using firewalls and two-step authentication, scanning systems periodically, and avoiding risky online behavior during active sessions.

- **Spyware:** A stealthy computer monitoring software that allows secret recording of all user activities on a target computer. It automatically delivers logs to the remote attacker using the Internet (via email, FTP, command and control through encrypted traffic, HTTP, DNS, etc.). The delivery logs include information about all areas of the system, such as emails sent, websites visited, every keystroke (including logins/passwords), file operations, and online chat conversations. It also takes screenshots at set intervals, just like a surveillance camera aimed at the computer monitor.

Spyware infects a user's system when they visit a fraudulent website containing malicious code controlled by the spyware author. This malicious code forcibly downloads and installs spyware on the user's computer.

Once spyware is installed, it monitors the user's activities on the Internet. This allows an attacker to gather information about a victim, including personal emails, online chat addresses, user logins, passwords, credit card information, and site credentials.

To prevent spyware infections, users should avoid using untrusted systems, keep browser and security settings on medium or high, avoid suspicious emails or downloads, and enable firewalls with outbound protection. Regular updates, use of anti-spyware tools, safe browsing habits, limited use of administrator mode, and careful software sourcing are essential to maintaining protection against spyware.

- **PUAs or Grayware: Potentially unwanted applications or programs** (PUAs or PUPs, respectively), also known as **grayware/junkware**, are potentially harmful applications that may pose severe risks to the security and privacy of data stored in the system where they are installed. Most PUAs originate from sources such as legitimate software packages and even malicious applications used for illegal activities. PUAs can degrade system performance and compromise privacy and data security.

Most PUAs get installed when downloading and installing freeware using a third-party installer or when accepting a misleading license agreement. PUAs can covertly monitor and alter the data or settings in the system, similarly to other malware.

Types of PUAs include Adware, Torrent, Marketing, Cryptomining, and Dialer.

To counter PUAs, users should download only from trusted sources, enable detection features in the OS or antivirus software, choose custom installation, and avoid express setup options. Regular updates, firewalls, cautious browsing habits, reading license agreements, and using reliable security tools help block unauthorized installations and prevent phishing-based downloads.

- **Keylogger:** A software programs or hardware device that record the keys struck on the computer keyboard (also called **keystroke logging**) of an individual computer user or a network of computers. It records almost all the keystrokes on a keyboard of a user and saves the recorded information in a text file. As keyloggers hide their processes and interface, the target is unaware of the keylogging.

Offices and industries use keyloggers to monitor employees' computer activities, and they can also be used in home environments for parents to monitor children's Internet activities.

Attackers use it illegally for malicious purposes, such as stealing sensitive and confidential information about victims. The data transmitted over the encrypted Internet connection is also vulnerable to keylogging because the keylogger tracks the keystrokes before encryption.

The keylogger program is installed onto the user's system invisibly through email attachments or "drive-by" downloads when users visit certain websites. Physical keystroke loggers "sit" between keyboard hardware and the OS, so that they can remain undetected and record every keystroke.

To defend against keyloggers, users should use anti-spyware, firewalls, updated security software, pop-up blockers, and avoid clicking suspicious links or emails. Additional measures include using on-screen keyboards or password managers, hardware checks, process-monitoring tools, input obfuscation, OTP authentication, encryption, and maintaining updated systems and drivers.

- **Botnets:** A collection of compromised computers connected to the Internet to perform a distributed task. Attackers distribute malicious software that turns a user's computer into a **bot**, which refers to a program or an infected system that performs repetitive work or acts as an agent or as a user interface to control other programs. The infected computer then performs automated tasks without the user's permission. Attackers use bots to infect a large number of computers.

Cyber-criminals who control bots are called **botmasters**. Bots spread across the Internet and search for vulnerable and unprotected systems. When it finds an exposed system, it quickly infects the system and reports back to the botmaster. Botmasters use infected computers to perform various automated tasks. They may instruct the infected systems to transmit viruses, worms, spam, and spyware.

- **Fileless Malware:** Also called **non-malware**, it infects legitimate software, applications, and other protocols existing in the system to perform various malicious activities. This type of malware leverages existing vulnerabilities to infect the system. It generally resides in the system's RAM. It injects malicious code into running processes.

Fileless malware does not depend on files and leaves no traces, thereby making it difficult to detect and remove using traditional anti-malware solutions. Therefore, such malware is highly resistant to computer forensics techniques.

To counter fileless malware, users should turn off unused tools like PowerShell, macros, and scripting in browsers, implement whitelisting and two-factor authentication, and monitor systems with User Behavior Analytics (UBA) and endpoint security. Regular system updates, antivirus scans, restricted privileges, behavioral baselining, and the use of AI-powered security tools or managed detection services further strengthen protection against memory-resident and script-based threats.

Vulnerability and Vulnerability Classification

Vulnerability

It refers to a weakness in the design or implementation of a system that can be exploited to compromise the security of the system. It is frequently a security loophole that enables an attacker to enter the system by bypassing user authentication.

Common Reasons for the Existence of Vulnerabilities:

- Hardware or software misconfiguration
- Insecure or poor design of the network and application
- Inherent technology weaknesses
- End-user carelessness
- Intentional end-user acts

Vulnerability Classifications

Vulnerabilities present in a system or network are classified into the following categories:

- **Misconfiguration:** This is the most common vulnerability and is mainly caused by human error, which allows attackers to gain unauthorized access to the system. It may happen intentionally or unintentionally and affect web servers, application platforms, databases, and networks.

Examples:

- An application running with debug enabled
- Running outdated software on the system
- Running unnecessary services on a machine
- Outbound connections to various Internet services
- Improperly authenticated external systems
- Incorrect folder permissions
- Default accounts or passwords
- Set up or configuration pages enabled
- Disabling security settings and features

Attackers can easily detect these misconfigurations using scanning tools and then exploit the backend systems. Therefore, the administrators must change the default configuration of devices and optimize device security.

- **Default Installations:** These are usually user-friendly, especially when the device is being used for the first time, when the primary concern is the usability of the device rather than the device's security. In some cases, infected devices may not contain any valuable information, but are connected to networks or systems that have confidential information that would result in a data breach. Failing to change the default settings while deploying the software or hardware allows the attacker to guess the settings to break into the system.
- **Buffer Overflows:** These are common software vulnerabilities that happen due to coding errors that allow attackers to gain access to the target system. In a buffer overflow attack, the attackers undermine the functioning of programs and try to take control of the system by writing content beyond the allocated size of the buffer. Insufficient bounds checking in the program is the root cause. The buffer is not able to handle data beyond its limit, causing the flow of data to adjacent memory locations and overwriting their data values. Systems often crash, become unstable, or show erratic behavior when a buffer overflow occurs.
- **Unpatched Servers:** An essential component of the infrastructure of any organization. There are several cases where organizations run unpatched and misconfigured servers that compromise the security and integrity of the data in their systems. Hackers look out for these vulnerabilities in the servers and exploit them. As these unpatched servers are a hub for the attackers, they serve as an entry point into the network. This can lead to the exposure of private data, financial loss, and the discontinuation of operations. Updating software regularly and maintaining systems properly by patching and fixing bugs can help in mitigating the vulnerabilities caused by unpatched servers.
- **Design Flaws:** Vulnerabilities due to design flaws are universal to all operating devices and systems. Design vulnerabilities, such as incorrect encryption or poor validation of data, are logical flaws in the functionality of the system that attackers exploit to bypass the detection mechanism and acquire access to a secure system.
- **Operating System Flaws:** Due to vulnerabilities in the operating systems, applications such as trojans, worms, and viruses pose threats. These attacks use malicious code, script, or unwanted software, which results in the loss of sensitive information and control of computer operations. Timely patching of the OS, installing minimal software applications, and using applications with firewall capabilities are essential steps that an administrator must take to protect the OS from attacks.
- **Application Flaws:** These are vulnerabilities in applications that attackers exploit. Applications should be secured using the validation and authorization of the user. Flawed applications have security threats such as data tampering and unauthorized access to configuration stores. If the applications are not secured, sensitive information may be lost or corrupted. Hence, developers must understand the anatomy of common security vulnerabilities.
- **Open Services:** Open ports and services may lead to the loss of data or DoS attacks and allow attackers to perform further attacks on other connected devices. Administrators must continuously check for unnecessary or insecure ports and services to reduce the risk to the network.
- **Default Passwords:** Manufacturers provide users with default passwords to access the device during its initial setup, which users must change for future use. When users forget to update their passwords and continue using the default passwords, they make devices and systems vulnerable to various attacks, such as brute force and dictionary attacks. Attackers exploit this vulnerability to obtain access

to the system. Passwords should be kept confidential; failing to protect the confidentiality of a password allows the system to be easily compromised.

- **Zero-Day Vulnerabilities:** Unknown vulnerabilities in software/hardware that are exposed but not yet patched. The attackers exploit these before being acknowledged and patched by the software developers or security analysts. Zero-day vulnerabilities are one of the major cyber threats that continuously expose vulnerable systems until they are repaired.
- **Legacy Platform Vulnerabilities:** These are exposed from old or familiar code. However, they could cause costly data breaches for organizations. Using these outdated codes, attackers can easily discover zero-day vulnerabilities in the system or software that are not yet patched.

Vulnerability Assessment and Types of Vulnerability Assessment

Vulnerability Assessment

This plays a major role in providing security to any organization's resources and infrastructure from various internal and external threats. It is an in-depth examination of the ability of a system or application, including current security procedures and controls, to withstand exploitation. It scans networks for known security weaknesses and recognizes, measures, and classifies security vulnerabilities in computer systems, networks, and communication channels. It identifies, quantifies, and ranks possible vulnerabilities to threats in a system.

Additionally, it assists security professionals in securing the network by identifying security loopholes or vulnerabilities in the current security mechanism before attackers can exploit them.

A vulnerability assessment may be used to:

- Identify weaknesses that could be exploited
- Predict the effectiveness of additional security measures in protecting information resources from attack

Vulnerability Scanning Approaches

There are two approaches to network vulnerability scanning:

- **Active Scanning:** The attacker interacts directly with the target network to find vulnerabilities. Active scanning helps in simulating an attack on the target network to uncover vulnerabilities that the attacker can exploit. For example, an attacker sends probes and specially crafted requests to the target host in the network to identify vulnerabilities.
- **Passive Scanning:** The attacker tries to find vulnerabilities without directly interacting with the target network. The attacker identifies vulnerabilities via information exposed by systems during normal communications. Passive scanning identifies the active operating systems, applications, and ports throughout the target network, monitoring activity to determine its vulnerabilities. This approach provides information about weaknesses but does not provide a path for directly combating attacks.

For example, an attacker guesses the operating system information, applications, and application and service versions by observing the TCP connection setup and teardown.

Types of Vulnerability Assessment

Given below are the different types of vulnerability assessments:

- **Active Assessment:** A type of vulnerability assessment that uses network scanners to identify the hosts, services, and vulnerabilities present in a network. Active network scanners can reduce the intrusiveness of the checks they perform.
- **Passive Assessment:** Passive assessments sniff the traffic present on the network to identify the active systems, network services, applications, and vulnerabilities. Passive assessments also provide a list of the users who are currently accessing the network.
- **External Assessment:** External assessment examines the network from a hacker's point of view to identify exploits and vulnerabilities accessible to the outside world. These types of assessments use external devices such as firewalls, routers, and servers. An external assessment estimates the threat of network security attacks from outside the organization. It determines the level of security of the external network and firewall.
- **Internal Assessment:** This involves scrutinizing the internal network to find exploits and vulnerabilities.
- **Host-based Assessment:** A type of security check that involves conducting a configuration-level check to identify system configurations, user directories, file systems, registry settings, and other parameters to evaluate the possibility of compromise. These assessments check the security of a particular network or server. Host-based scanners assess systems to identify vulnerabilities such as native configuration tables, incorrect registry or file permissions, and software configuration errors. Host-based assessments use many commercial and open-source scanning tools.
- **Network-based Assessment:** This determines the possible network security attacks that may occur on an organization's system. These assessments discover network resources and map the ports and services running to various areas of the network. It evaluates the organization's system for vulnerabilities such as missing patches, unnecessary services, weak authentication, and weak encryption. Network assessment professionals use firewalls and network scanners, such as Nessus. These scanners identify open ports, recognize the services running on those ports, and detect vulnerabilities associated with these services.
- **Application Assessment:** Focuses on transactional web applications, traditional client-server applications, and hybrid systems. It analyzes all elements of an application infrastructure, including deployment and communication with the client and server. This type of assessment tests the web server infrastructure for any misconfiguration, outdated content, or known vulnerabilities. Security professionals use both commercial and open-source tools to perform such assessments.
- **Database Assessment:** This is any assessment focused on testing the databases for the presence of any misconfiguration or known vulnerabilities. These assessments mainly concentrate on testing various database technologies like MYSQL, MSSQL, ORACLE, and POSTGRESQL to identify data exposure or injection-type vulnerabilities. Security professionals use both commercial and open-source tools to perform such assessments.
- **Wireless Network Assessment:** Determines the vulnerabilities in an organization's wireless networks. In the past, wireless networks used weak and defective data encryption mechanisms. Now, wireless network standards have evolved, but many networks still use weak and outdated security mechanisms and are open to attack. Wireless network assessments try to attack wireless authentication mechanisms and gain unauthorized access. This type of assessment tests wireless networks and identifies rogue networks that may exist within an organization's perimeter.

- **Distributed Assessment:** This type of assessment, employed by organizations that possess assets like servers and clients at different locations, involves simultaneously assessing the distributed organization assets, such as client and server applications, using appropriate synchronization techniques. Synchronization plays a critical role in this type of assessment. By synchronizing the test runs together, all the separate assets situated at multiple locations can be tested at the same time.
- **Credentialed Assessment:** or **authenticated assessment**, wherein the security professional possesses the credentials of all machines present in the assessed network. The chances of finding vulnerabilities related to operating systems and applications are higher in credential assessment than in non-credentialed assessment. This type of assessment is challenging since it is highly unclear who owns particular assets in large enterprises, and even when the security professional identifies the actual owners of the assets, accessing the credentials of these assets is highly tricky since the asset owners generally do not share such confidential information. Also, even if the security professional successfully acquires all required credentials, maintaining the password list is a huge task since there can be issues with things like changed passwords, typing errors, and administrative privileges.
- **Non-credentialed Assessment,** or **unauthenticated assessment**, provides a quick overview of weaknesses by analyzing the network services that the host exposes. Since it is a non-credential assessment, a security professional does not require any credentials for the assets to perform their assessments. This type of assessment generates a brief report regarding vulnerabilities; however, it is not reliable because it does not provide deeper insight into the OS and application vulnerabilities that the host does not expose to the network. This assessment is also incapable of detecting the vulnerabilities that are potentially covered by firewalls. It is prone to false-positive outputs and is not reliably effective as compared to credential-based assessment.
- **Manual Assessment:** After performing footprinting and network scanning and obtaining crucial information, if the security professional performs manual research for exploring the vulnerabilities or weaknesses, they manually rank the vulnerabilities and score them by referring to vulnerability scoring standards like CVSS (Common Vulnerability Scoring System) and vulnerability databases like CVE (Common Vulnerabilities and Exposures) and CWE (Common Weakness Enumeration). Such assessments are considered to be manual.
- **Automated Assessment:** An assessment where a security professional uses vulnerability assessment tools such as Nessus, Qualys, or GFI LanGuard to perform a vulnerability assessment of the target is called an automated assessment. Unlike manual assessments, the security professional does not perform footprinting and network scanning. They employ computerized tools that can perform all such activities and are also capable of identifying weaknesses and CVSS scores, acquiring critical CVE/CWE information related to the vulnerability, and suggesting remediation strategies.

Vulnerability-Management Cycle

The vulnerability management life cycle is an important process that helps identify and remediate security weaknesses before they can be exploited. The implementation of a vulnerability management lifecycle helps gain a strategic perspective regarding possible cybersecurity threats and renders insecure computing environments more resilient to attacks.

The phases involved in vulnerability management are:

- **Identify Assets and Create a Baseline:** This phase identifies critical assets and prioritizes them to define the risk based on the criticality and value of each system. This creates a good baseline for vulnerability management. This phase involves the gathering of information about the identified

systems to understand the approved ports, software, drivers, and basic configuration of each system in order to develop and maintain a system baseline.

- **Vulnerability Scan:** This phase is very crucial in vulnerability management. In this step, the security analyst performs a vulnerability scan on the network to identify the known vulnerabilities in the organization's infrastructure. This can also be performed on applicable compliance templates to assess the organization's infrastructure weaknesses against the respective compliance guidelines.
- **Risk Assessment:** In this phase, all serious uncertainties that are associated with the system are assessed and prioritized, and remediation is planned to permanently eliminate system flaws. The risk assessment summarizes the vulnerability and risk level identified for each of the selected assets. It determines whether the risk level for a particular asset is high, moderate, or low.
- **Remediation:** The process of applying fixes to vulnerable systems in order to reduce the impact and severity of vulnerabilities. This phase is initiated after the successful implementation of the baseline and assessment steps.
- **Verification:** In this phase, the security team performs a re-scan of systems to assess if the required remediation is complete and whether the individual fixes have been applied to the impacted assets. This phase provides clear visibility into the firm and allows the security team to check whether all the previous phases have been perfectly employed or not. Verification can be performed by using various means such as ticketing systems, scanners, and reports.
- **Monitor:** Organizations need to perform regular monitoring to maintain system security. They use tools such as IDS/IPS and firewalls. Continuous monitoring identifies potential threats and any new vulnerabilities that have evolved. As per security best practices, all phases of vulnerability management must be performed regularly.

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.